

Web SQL Injection Lab Setup Guide

[Created on Mar 22, 2022; Updated on Mar 09, 2024]

1. เปิดไฟล์ /etc/hosts ในเครื่อง SEED-Ubuntu20.04 VM โดยเพิ่มบรรทัดด้านล่างในไฟล์

```
10.9.0.5      www.seed-server.com
```

หมายเหตุ ถ้าแอดเดรสที่ถูกแมพกับไอพีแอดเดรสอื่น เนื่องจากการทำแล็บอื่นที่นักศึกษาได้รับมอบหมาย นักศึกษาต้องบันทึกข้อมูลใหม่ตามเอกสารนี้

2. ดาวน์โหลดไฟล์ LabSetup.zip สำหรับแล็บ Web SQL Injection ลงบนเครื่อง SEED-Ubuntu20.04 VM

3. แยก (extract) ไฟล์ LabSetup.zip ในโฟลเดอร์ที่ต้องการบนเครื่อง VM

เช่น แยกไฟล์ LabSetup.zip ที่โฟลเดอร์ ~/Web_SQL_Injection จะได้ผลลัพธ์ดังนี้

```
[03/20/22]seed@VM:~/Web_SQL_Injection$ ls
docker-compose.yml  image_mysql  image_www  Labsetup.zip
```

4. เข้าไปที่โฟลเดอร์ซึ่งมีผลลัพธ์จากการแตกไฟล์ LabSetup.zip ไว้

4.1. ลองลิสต์ไฟล์ทั้งหมดในโฟลเดอร์ดู

นักศึกษาควรเห็นไฟล์ชื่อ docker-compose.yml ถูกลิสต์ขึ้นมาด้วย

ยกตัวอย่างเช่น ถ้าดำเนินการตามตัวอย่างในข้อ 2. ที่โฟลเดอร์ ~/Web_SQL_Injection

จะมีไฟล์ docker-compose.yml อยู่ ดังภาพตัวอย่าง

```
[03/20/22]seed@VM:~/Web_SQL_Injection$ ls
docker-compose.yml  image_mysql  image_www  Labsetup.zip
```

4.2. ถ้าพบไฟล์ดังข้อ 4.1. ออกคำสั่ง `$ docker-compose up &`

เพื่อสร้างอิมเมจ สร้างคอนเทนเนอร์ และรันคอนเทนเนอร์ (container) จำนวน 2 คอนเทนเนอร์

แต่ละคอนเทนเนอร์บรรจุอิมเมจ (image) ของซอฟต์แวร์ ดังนี้

(1) เว็บเซิร์ฟเวอร์และเว็บไซต์

(2) ฐานข้อมูล mysql

```
[03/20/22]seed@VM:~/Web_SQL_Injection$ docker-compose up &
[1] 6904
Creating www-10.9.0.5    ... done
Creating mysql-10.9.0.6 ... done
```

<The rest of output is omitted!!! >

ตรวจสอบคอนเทนเนอร์ที่รันอยู่ด้วยคำสั่ง `$ docker ps` ควรได้ผลลัพธ์ ดังนี้

[03/20/22]seed@VM:~/Web_SQL_Injections\$ docker ps						
CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAMES
07e893eddce2	seed-image-mysql-sqli	"docker-entrypoint.s..."	7 minutes ago	Up 7 minutes	3306/tcp, 33060/tcp	mysql-10.9
.0.6						
f9ab62c850c8	seed-image-www-sqli	"/bin/sh -c 'service..."	7 minutes ago	Up 7 minutes		www-10.9.0
.5						

หมายเหตุ-1: ไฟล์ docker-compose.yml บรรจุชุดคำสั่งสำหรับการจัดการอิมเมจและคอนเทนเนอร์ของแล็บนี้

แนะนำให้นักศึกษาทดลองใช้ editor เช่น vim, emacs, nano เพื่อศึกษาข้อมูลภายในไฟล์ docker-compose.yml นี้ จะทำให้เข้าใจขั้นตอนนี้นมากขึ้น

หมายเหตุ-2:

You can run the following command to run the docker-compose.yml file:

```
docker-compose -f {compose file name} up
```

You can ignore the -f flag if your file name is docker-compose.yml

5. การรันคำสั่งเพื่อสั่งงานแต่ละคอนเทนเนอร์ เราจะต้องเรียก shell ของแต่ละคอนเทนเนอร์ขึ้นมารับคำสั่งนั้น ๆ

To run commands on a container, we often need to get a shell on that container.

การเรียก shell ของแต่ละคอนเทนเนอร์ใช้คำสั่ง

```
$ docker exec -it <container ID> /bin/bash
```

หมายเหตุ -it หมายถึง interactive option

หมายเหตุ การระบุ container ID ไม่จำเป็นต้องระบุตัวเลขครบทุกตัว สามารถพิมพ์เฉพาะตัว 2-3 ตัวแรก ที่ทำให้สามารถระบุคอนเทนเนอร์ตัวใดตัวหนึ่งได้อย่างแน่ชัด

```
[03/20/22]seed@VM:~/Web_SQL_Injection$ docker exec -it 07e893eddce2 /bin/bash
root@07e893eddce2:/# ← shell ของคอนเทนเนอร์หมายเลข 07e893eddce2 (ติดตั้งฐานข้อมูล mysql)
```

6. เกี่ยวกับฐานข้อมูล MySQL database

ในแล็บนี้ ฐานข้อมูลมายเอสคิวแอล (MySQL Database) อยู่ภายในคอนเทนเนอร์ ชื่อ mysql-10.9.0.6

สำหรับแล็บนี้ เราต้องการเก็บข้อมูลภายใน MySQL database ไว้ แม้ว่าคอนเทนเนอร์จะถูกทำลายไปแล้ว

ดังนั้น จะมีการสร้างและผูกโฟลเดอร์ mysql_data ภายในเครื่อง VM กับโฟลเดอร์ /var/lib/mysql ภายในคอนเทนเนอร์ MySQL เพื่อจัดเก็บข้อมูลของฐานข้อมูลไว้

โฟลเดอร์ mysql_data ภายในเครื่อง VM จะไม่ถูกทำลาย แม้ว่าคอนเทนเนอร์จะถูกทำลายไปแล้ว

ดังนั้น หากเราต้องการเริ่มต้นฐานข้อมูลใหม่เลย (clean database) ต้องลบโฟลเดอร์ mysql_data บนเครื่อง VM ออกไป ด้วยคำสั่ง

```
$ sudo rm -f mysql_data
```

7. เกี่ยวกับเว็บแอปพลิเคชัน (About Web Application)

เว็บแอปพลิเคชันในเล่มนี้เป็นแอปพลิเคชันแบบง่ายสำหรับการจัดการข้อมูลพนักงาน (simple employee management application)

ผู้ใช้ของแอปพลิเคชันมี 2 บทบาท ได้แก่ Administrator และ Employee

- Employee: สามารถเรียกดู (view) และ อัปเดต (update) ข้อมูลของตนเองได้
- Administrator: มีสิทธิพิเศษสามารถจัดการข้อมูลของพนักงานแต่ละคนได้

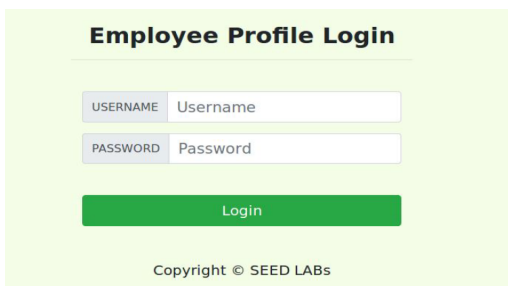
ข้อมูลของพนักงานทุกคนในฐานข้อมูลถูกจัดแสดงในตาราง Table 1.

Table 1: Database

Name	Employee ID	Password	Salary	Birthday	SSN	Nickname	Email	Address	Phone#
Admin	99999	seedadmin	400000	3/5	43254314				
Alice	10000	seedalice	20000	9/20	10211002				
Boby	20000	seedboby	50000	4/20	10213352				
Ryan	30000	seedryan	90000	4/10	32193525				
Samy	40000	seedsamy	40000	1/11	32111111				
Ted	50000	seedted	110000	11/3	24343244				

8. ที่เครื่อง VM เปิดเว็บเบราว์เซอร์ และพิมพ์ URL `www.seed-server.com`

เบราว์เซอร์ของเครื่อง VM ต้องแสดงหน้าล็อกอินเพจ ดังรูปด้านล่าง

	เมื่อดำเนินการเสร็จสิ้นทั้ง 8 ขั้นตอนนี้แล้ว นักศึกษา ก็พร้อมที่จะทำงานตามที่กำหนดในหัวข้อ 3. Lab Tasks โดยในแต่ละ Task ให้นักศึกษาดำเนินการตามคำสั่งและ สภาพแวดล้อมที่ตั้งค่าไว้ และตอบคำถามพร้อมอภิปรายเหตุผลและแสดงหน้าจอประกอบ ด้วย
--	---